

Data Protection by Design

Embedding data protection into processing from the outset and by default

GLOSSARY 06 - SHEET 7 / 8

PROFESSIONAL DEFINITION

Data protection by design and by default is the legal obligation, under Article 25 of the General Data Protection Regulation, to implement appropriate technical and organisational measures that give effect to the data-protection principles at the time processing means are determined and during processing itself, and to ensure that by default only personal data necessary for each specific purpose is processed. It converts a design philosophy into a binding duty on the controller (Regulation (EU) 2016/679, Article 25; Cavoukian, 2009).

WHO DEFINED IT ORIGINALLY

The privacy by design philosophy and its seven foundational principles were formulated by Ann Cavoukian as Information and Privacy Commissioner of Ontario in the 1990s and set out formally in 2009, receiving international recognition at the 2010 conference of data protection commissioners. It was made a legal obligation by Article 25 of the GDPR, applicable from 25 May 2018.

WHY THIS DEFINITION WAS DEVELOPED

Privacy protection was applied at the end of development as a compliance review, by which point the architecture had already determined what data would be collected and retained, and remediation was expensive or impossible. Moving the obligation to the point at which processing means are determined makes protection an architectural constraint rather than a subsequent review.

HOW IT IS USED

Determine the lawful basis, minimise the data and set the retention period before the architecture is fixed; configure the default to the most protective setting, since Article 25 requires protection by default rather than as a user-selected option.

WHEN IT IS USED

At the determination of processing means, before an AI system is trained on personal data, at data protection impact assessment, and at any change of processing purpose.

BY WHOM IT IS USED

Data protection officers, system architects and engineers, product owners defining processing purposes, and controllers who bear the legal obligation.

FIGURE 1 - WHERE PROTECTION IS DETERMINED

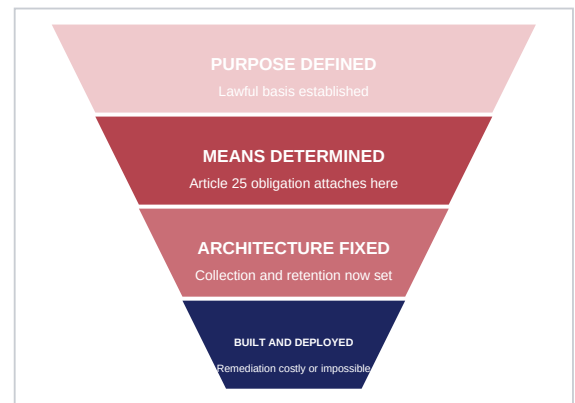


Figure 1. The obligation attaches at the second stage, before the architecture constrains what is possible. A data-protection review conducted at the fourth stage can document the position but can no longer change it (after Regulation (EU) 2016/679, Article 25).

INNOVATION RELATIVE TO THE PREDECESSOR TOOL

The predecessor practice was notice and consent, which placed the burden on the individual to read a policy and accept it, and which permitted extensive collection provided it was disclosed. Article 25 shifts the burden to the controller and makes minimisation a default state rather than an option, so the protective configuration obtains without any action by the data subject. For AI this bites at the point of training-data assembly, where the temptation to retain everything is strongest.

RELATED DEFINITIONS IN THIS COURSE

Data Strategy - Unit 3

AI Governance - Unit 6

EU AI Act - Unit 6

Trustworthy AI - Unit 6

Algorithmic Bias - Unit 6

SOURCES (HARVARD REFERENCING STYLE)

Cavoukian, A. (2009) Privacy by Design: The 7 Foundational Principles. Toronto: Information and Privacy Commissioner of Ontario.
European Data Protection Board (2020) Guidelines 4/2019 on Article 25 Data Protection by Design and by Default, version 2.0. Brussels: EDPB.
European Parliament and Council (2016) Regulation (EU) 2016/679 (General Data Protection Regulation), Article 25. Official Journal of the European Union, L119, 4 May 2016.